

INCIDENT RESPONSE PLAYBOOK

Ransomware Attack Response

Version 1.0

1. Purpose & Scope

This Incident Response (IR) Playbook provides a structured, step-by-step guide for SOC analysts and incident responders to detect, contain, eradicate, and recover from ransomware attacks. It follows the NIST SP 800-61 Incident Response Framework.

Field	Details
Playbook Type	Ransomware Incident Response
Framework	NIST SP 800-61 Rev 2
Severity	CRITICAL
Target Audience	SOC Analysts, IR Team, IT Security
Review Cycle	Every 6 months

2. Roles & Responsibilities

Role	Responsibility	Contact
SOC Analyst (L1)	Initial detection, alert triage, escalation	SOC Team
SOC Analyst (L2)	Deep investigation, containment actions	SOC Lead
Incident Commander	Overall IR coordination and decisions	Security Manager
IT Admin	System isolation, backup restoration	IT Team
Legal/Compliance	Regulatory notification, legal guidance	Legal Team
Management	Business decisions, ransom decisions	CISO/CTO
Communications	Internal/external communications	PR Team

3. Ransomware Attack Overview

3.1 What is Ransomware?

Ransomware is malware that encrypts victim files, making them inaccessible, and demands payment (usually cryptocurrency) for the decryption key. Modern ransomware also exfiltrates data before encryption for double extortion.

3.2 Common Attack Vectors

Vector	Description	Prevalence
Phishing Email	Malicious attachment or link in email	HIGH
RDP Brute Force	Attackers crack Remote Desktop credentials	HIGH
Vulnerable Software	Exploiting unpatched CVEs	HIGH
Supply Chain	Compromised third-party software	MEDIUM
Insider Threat	Malicious employee action	LOW
USB/Physical	Infected physical media	LOW

3.3 Ransomware Kill Chain

Phase	Attacker Action	Detection Opportunity
1. Initial Access	Phishing, exploit, stolen creds	Email gateway, IDS alerts
2. Execution	Malware runs on victim system	EDR, AV detection
3. Persistence	Registry keys, scheduled tasks	SIEM correlation rules
4. Lateral Movement	SMB, RDP, credential dumping	Network traffic analysis
5. Exfiltration	Data copied to attacker server	DLP, unusual outbound traffic
6. Encryption	Files encrypted, ransom note dropped	File system monitoring
7. Extortion	Ransom demand received	After the fact

4. Detection & Identification

4.1 Indicators of Compromise (IOCs)

Network IOCs:

- Unusual outbound traffic to unknown IPs especially on ports 443, 80, 4444
- Large data transfers outside business hours
- Connections to Tor exit nodes or known C2 servers
- SMB lateral movement traffic (port 445) between workstations
- DNS queries to newly registered or suspicious domains
- Port scanning activity from internal hosts

Host IOCs:

- Files with unusual extensions: .locked, .encrypted, .crypto, .ransom
- README.txt, HOW_TO_DECRYPT.txt, or similar ransom notes
- Rapid file modification events across multiple directories
- Shadow copy deletion: vssadmin delete shadows /all
- Unusual processes: cmd.exe, powershell.exe spawned from Office apps
- Registry modifications in HKLM\Software\Microsoft\Windows\CurrentVersion\Run
- Disabled Windows Defender or other security tools
- High CPU/disk usage from encryption process

SIEM Alert Rules to Monitor:

Rule Name	Trigger Condition	Severity
Mass File Rename	>100 file extensions changed in 60 seconds	CRITICAL
Shadow Copy Delete	vssadmin or wmic shadowcopy delete command	CRITICAL
Ransomware Extension	Known ransomware file extensions detected	CRITICAL
C2 Communication	Traffic to known malicious IPs/domains	HIGH
Credential Dumping	lsass.exe memory access or mimikatz signatures	HIGH
Lateral Movement	Unusual SMB connections between hosts	HIGH

Security Tool Disabled	AV/EDR process terminated	HIGH
Unusual Admin Activity	Admin tools run outside business hours	MEDIUM

5. Incident Response Phases

Phase 1: Preparation

Actions to take BEFORE an incident occurs to ensure readiness.

Task	Owner	Status
Maintain updated asset inventory	IT Admin	Ongoing
Ensure backups are tested and offline	IT Admin	Weekly
Deploy EDR on all endpoints	Security Team	Ongoing
Configure SIEM alerting rules	SOC Team	Ongoing
Train staff on phishing awareness	HR/Security	Quarterly
Test IR playbook with tabletop exercises	IR Team	Bi-annually
Establish communication tree	Management	Annually
Maintain contact list of vendors/law enforcement	IR Lead	Annually

Phase 2: Detection & Analysis

Steps to take immediately upon receiving an alert or report of suspicious activity.

- Receive alert from SIEM, EDR, user report, or automated tool
- Log incident in ticketing system with timestamp and initial details
- Assign severity level based on IOCs observed
- Identify affected systems, users, and business impact
- Preserve evidence — take memory dumps and disk images if possible
- Determine attack vector and entry point
- Escalate to L2/IR team based on severity

Severity	Criteria	Response Time	Escalation
CRITICAL	Active encryption, data exfiltration	Immediate	IR Team + Management
HIGH	Malware detected, suspicious lateral movement	15 minutes	L2 SOC Analyst
MEDIUM	Phishing email opened, no execution	1 hour	L1 SOC Analyst
LOW	Suspicious email received, no action taken	4 hours	L1 SOC Analyst

Phase 3: Containment

Immediate actions to stop the spread of ransomware. Speed is critical!

Short-term Containment (First 30 minutes):

- ISOLATE affected systems immediately — disconnect from network
- Disable affected user accounts to prevent further access
- Block attacker IP addresses at firewall and perimeter
- Preserve system state — do NOT reboot affected machines
- Alert all users to be suspicious of unusual activity
- Disable VPN access if remote attack vector is suspected
- Contact ISP if DDoS component is detected

Long-term Containment (First 4 hours):

- Identify all affected systems through network traffic analysis
- Segment affected network segment from rest of infrastructure
- Deploy additional monitoring on unaffected systems
- Review firewall logs for lateral movement patterns
- Reset all privileged account credentials
- Enable enhanced logging on all remaining systems

Phase 4: Eradication

Remove the threat completely from the environment before recovery begins.

- Identify malware strain using VirusTotal, ANY.RUN, or sandbox
- Remove all malware artifacts, persistence mechanisms, and backdoors
- Delete malicious scheduled tasks and registry entries
- Patch the vulnerability used for initial access
- Reset ALL passwords — assume all credentials compromised
- Rebuild compromised systems from clean golden images
- Verify no remnants using EDR scan on all systems
- Conduct threat hunt across environment for similar IOCs

Phase 5: Recovery

Restore systems and operations in a controlled, safe manner.

- Verify clean backups exist from before infection date
- Restore from clean backup — newest pre-infection backup
- Test restored systems thoroughly before reconnecting to network
- Monitor restored systems closely for 72 hours
- Gradually restore network connectivity with enhanced monitoring
- Verify all business-critical systems are operational
- Communicate with stakeholders about recovery status
- Document all recovery steps taken

Phase 6: Lessons Learned

Conduct post-incident review within 2 weeks of containment.

- Schedule post-incident review meeting with all stakeholders
- Document complete incident timeline from detection to recovery
- Identify root cause and how attacker gained initial access
- List all gaps in detection and response capabilities
- Update detection rules and playbooks based on findings
- Implement additional controls to prevent recurrence
- Report findings to management and board if required
- Share anonymized threat intelligence with industry peers

6. Communication Templates

6.1 Internal Alert — Initial Notification

Subject: URGENT — Ransomware Incident Detected [SEV-1] Team, We have detected a potential ransomware infection affecting [AFFECTED SYSTEMS]. The SOC team is actively investigating and responding. Please take the following immediate actions: 1. Do NOT open any suspicious emails or attachments 2. Do NOT access shared network drives until further notice 3. Report any unusual system behaviour immediately to the SOC: [SOC CONTACT] Updates will be provided every 30 minutes. This is a CRITICAL incident. VIJAY S — SOC Analyst

6.2 Management Escalation Template

Subject: CRITICAL — Ransomware Incident Escalation Incident Summary: Detection Time: [DATE/TIME] Affected Systems: [NUMBER] systems in [DEPARTMENT] Data at Risk: [DESCRIPTION OF DATA] Current Status: [CONTAINMENT/ERADICATION/RECOVERY] Business Impact: [DESCRIPTION] Decision Required: [YES/NO — specify what decision is needed] Next Update: [TIME]

6.3 Regulatory Notification Checklist

Regulation	Notification Required	Deadline	Authority
GDPR	Personal data breach	72 hours	Data Protection Authority
HIPAA	PHI breach > 500 records	60 days	HHS OCR
PCI DSS	Cardholder data breach	Immediately	Card Brands + Acquirer
IT Act (India)	Data breach affecting users	As soon as possible	CERT-In
SEBI	Market sensitive data breach	Immediately	SEBI

7. Evidence Collection Checklist

Proper evidence collection is critical for forensic investigation and legal proceedings.

Evidence Type	Collection Method	Storage Location	Collected?
Memory Dump	winpmem, LiME (Linux)	/evidence/memory/	[]

Disk Image	FTK Imager, dd	/evidence/disk/	[]
Network Logs	Firewall, IDS/IPS logs	/evidence/network/	[]
SIEM Logs	Export relevant timeframe	/evidence/siem/	[]
Endpoint Logs	Windows Event Logs, Syslog	/evidence/endpoints/	[]
Malware Samples	Isolated copy of malware	/evidence/malware/	[]
Ransom Notes	Screenshot and copy	/evidence/ransom/	[]
Wireshark Captures	.pcap files of attack traffic	/evidence/pcap/	[]
Email Headers	Original phishing email	/evidence/email/	[]
Timeline	Chronological event log	/evidence/timeline/	[]

8. Wireshark Detection Signatures

Based on lab analysis, the following Wireshark filters can detect ransomware-related activity:

8.1 Port Scan Detection

Filter	What it Detects
<code>tcp.flags.syn == 1 && tcp.flags.ack == 0</code>	Nmap SYN scan — attacker probing ports
<code>tcp.window_size == 1024</code>	Nmap default window size signature
<code>tcp.flags.reset == 1</code>	Mass RST = port scan in progress
<code>ip.src == [ATTACKER_IP]</code>	All traffic from suspicious source

8.2 Exploit Traffic Detection

Filter	What it Detects
<code>tcp.port == 445</code>	SMB traffic — check for exploitation
<code>smb.cmd == 0x73</code>	SMB Session Setup — check username field
<code>tcp.port == 4444</code>	Common Metasploit reverse shell port
<code>tcp.flags.push == 1</code>	Data transfer — may be C2 or exfiltration

8.3 Data Exfiltration Detection

Filter	What it Detects
<code>tcp.len > 1000 && ip.dst != [INTERNAL_RANGE]</code>	Large packets leaving network
<code>dns.qry.name contains ".onion"</code>	Tor network communication
<code>http.request.method == POST</code>	Data being uploaded via HTTP
<code>ftp.request.command == STOR</code>	Files being uploaded via FTP

9. Recovery Checklist

Phase	Task	Owner	Done?
Pre-Recovery	Confirm attacker has been evicted	IR Lead	[]
Pre-Recovery	Verify clean backup exists	IT Admin	[]
Pre-Recovery	Test backup integrity	IT Admin	[]
Recovery	Restore from clean backup	IT Admin	[]
Recovery	Apply all security patches	IT Admin	[]

Recovery	Reset all credentials	IT Admin	[]
Recovery	Deploy additional monitoring	SOC Team	[]
Post-Recovery	Monitor for 72 hours	SOC Team	[]
Post-Recovery	Verify business operations	Management	[]
Post-Recovery	Conduct lessons learned	IR Lead	[]
Post-Recovery	Update playbook	SOC Team	[]
Post-Recovery	File regulatory notifications	Legal	[]

10. IR Metrics & KPIs

Metric	Definition	Target
Mean Time to Detect (MTTD)	Time from attack start to detection	< 1 hour
Mean Time to Respond (MTTR)	Time from detection to containment	< 4 hours
Mean Time to Recover (MTTRC)	Time from detection to full recovery	< 24 hours
False Positive Rate	% of alerts that are not real incidents	< 10%
Containment Time	Time to isolate affected systems	< 30 minutes
Evidence Preservation Rate	% of incidents with complete evidence	> 95%

11. References & Resources

- NIST SP 800-61 Rev 2 — Computer Security Incident Handling Guide
- MITRE ATT&CK Framework — <https://attack.mitre.org>
- No More Ransom Project — <https://www.nomoreransom.org>
- CERT-In Guidelines — <https://www.cert-in.org.in>
- CIS Controls v8 — <https://www.cisecurity.org/controls>
- SANS Incident Response Handbook
- Ransomware Response Checklist — CISA

Field	Details
Author	VIJAY S
Email	reachvijays20@gmail.com
LinkedIn	linkedin.com/in/vijaycybersecurity
GitHub	github.com/JacobVijay26
Date	June 18, 2026
Version	1.0 — Initial Release
Next Review	December 2026